AWS - Hardening de Identidades y Gobernanza

Proyecto: Aseguramiento de Cuenta Raíz y Delegación de privilegios.

Responsable: Tony (Cloud Architect)

1. Resumen Ejecutivo

Se implementó un esquema de seguridad basado en el principio de **Mínimo Privilegio** y el **AWS Well-Architected Framework**. El objetivo fue mitigar el riesgo de compromiso de la cuenta raíz y prevenir errores operacionales catastróficos mediante el uso de hardware físico y políticas preventivas.

2. Implementaciones Técnicas

A. Gestión de Identidades (IAM)

- **Delegación de Privilegios:** Se creó un usuario administrador (`admin`) para operaciones diarias, permitiendo el aislamiento total de las credenciales de la cuenta Raíz (Root).
- **MFA por Hardware (FIDO2/WebAuthn):** Se vinculó una llave física **YubiKey** como único factor de autenticación fuerte, eliminando vectores de ataque como el *SIM Swapping* o *Phishing*.

B. Políticas de Seguridad (Guardrails)

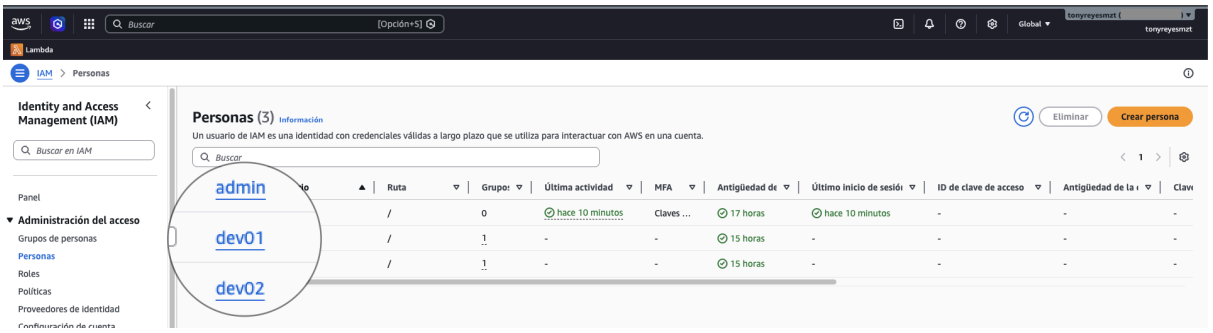
Se desarrolló e implementó una política personalizada en JSON denominada `IAM-Policy-Prevent-Accidental-Deletion`.

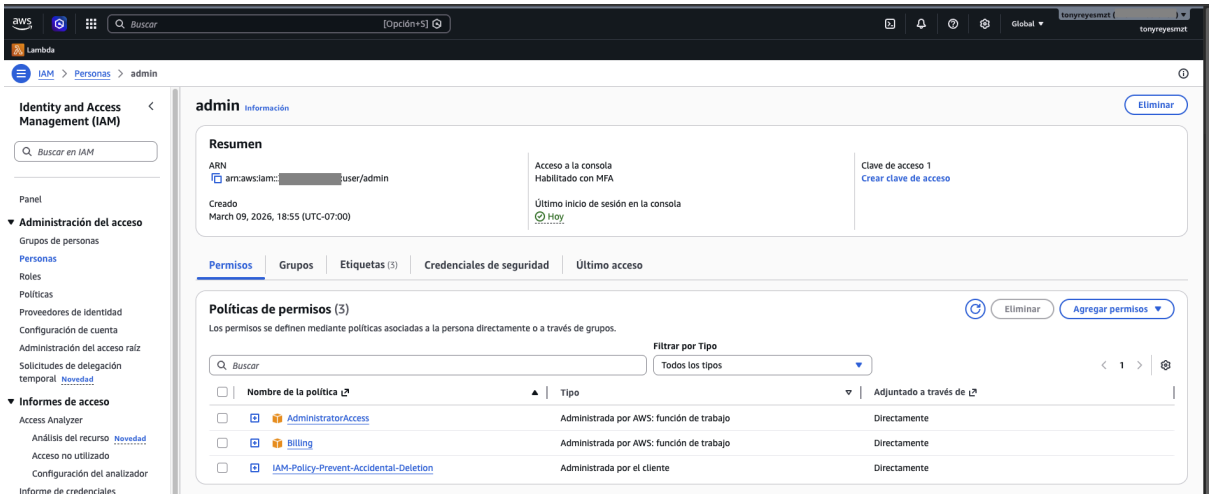
- **Lógica:** Implementa un `Deny` explícito sobre acciones críticas (`s3:DeleteBucket`, `rds:DeleteDBInstance`, `ec2:TerminateInstances`).
- **Condición:** La restricción solo se levanta si el contexto de la sesión incluye una validación de MFA activa (`aws:MultiFactorAuthPresent: true`).

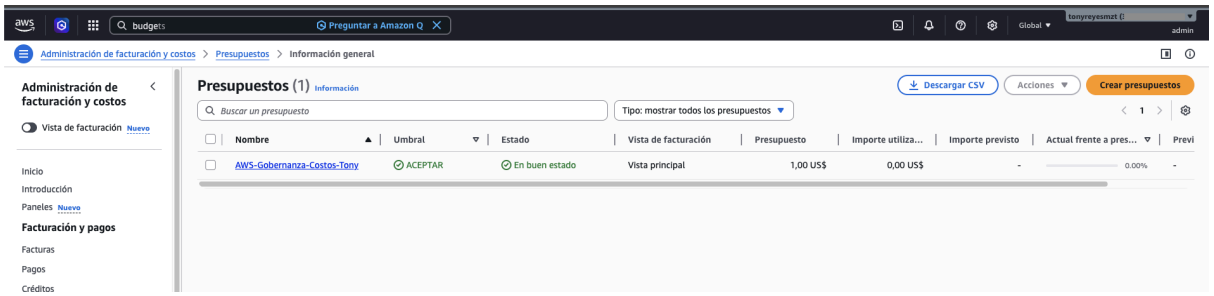
C. Gobernanza Financiera

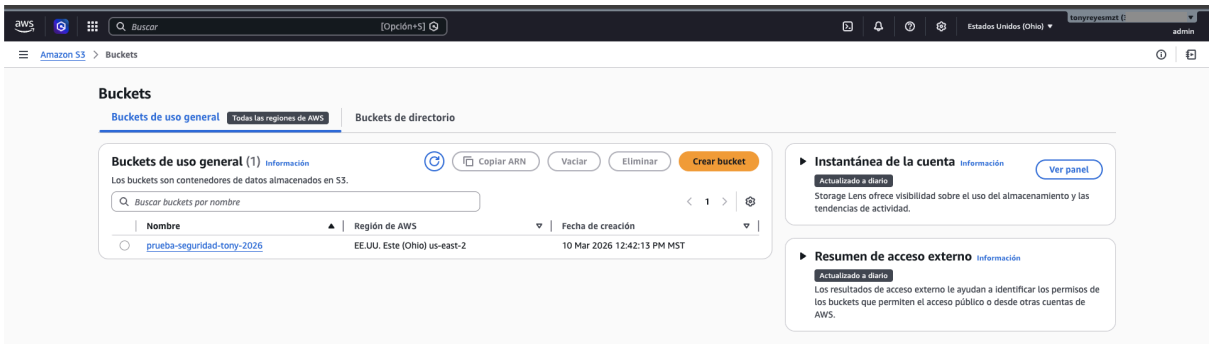
- **Activación de Acceso a Facturación:** Se habilitó el interruptor maestro de cuenta para permitir la monitorización de costos desde roles delegados.
- **AWS Budgets:** Configuración de un presupuesto de **$1.00 USD** con alertas automatizadas vía Email al alcanzar el 80% del umbral previsto.

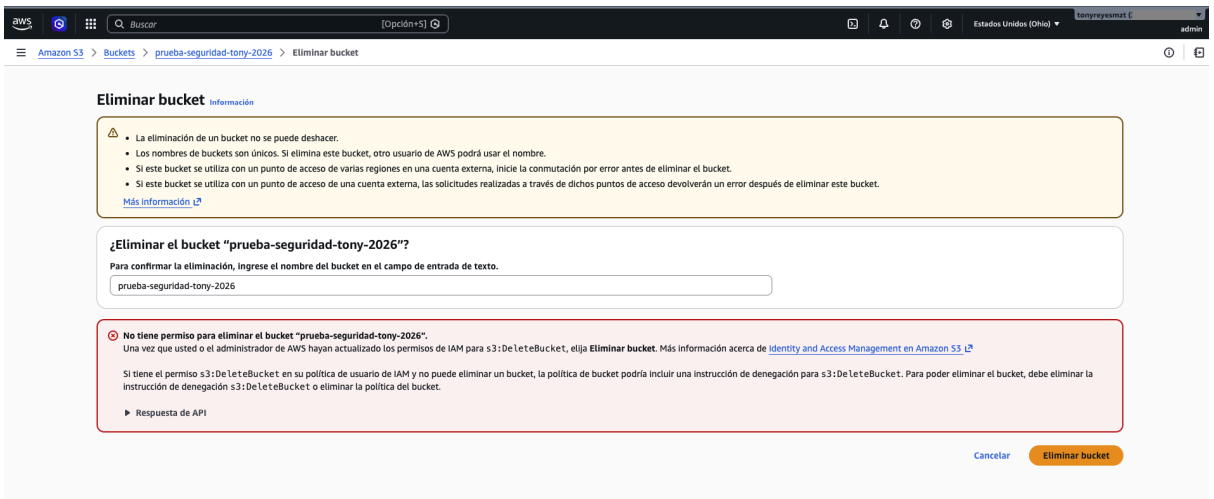
3. Evidencias de Verificación











- **Acceso:** Verificación de acceso exitoso mediante usuario IAM delegando la cuenta raíz.
- **Costo:** Panel de facturación visible y funcional desde el usuario `admin`.
- **Seguridad:** El sistema deniega intentos de borrado si la YubiKey no está presente.